UNIVERSIDAD NACIONAL DEL ALTIPLANO
FACULTAD DE INGENIERÍA MECÁNICA ELÉCTRICA Y DE SISTEMAS

Plan Integral de Ciberseguridad Institucional

Caso de Aplicación: Universidad Nacional del Altiplano de Puno (UNAP)

PRESENTADO POR:
QUISPE CHATA CARLOS DAVID

DOCENTE:
TICONA YANQUI FIDEL ERNESTO

SEMESTRE: IX

PUNO – 2026

ÍNDICE GENERAL

Sección Preliminar: Declaración Ética, Marco Legal y Metodología 1

1 Datos Generales de la Entidad 4

1.1 Ficha Técnica Institucional 4
1.2 Estructura Orgánica y Roles de Seguridad 4

2 Introducción 5

2.1 Contexto y Relevancia Institucional 5
2.2 Caracterización de la Superficie Expuesta Universitaria 5
2.3 Transición hacia un Modelo de Defensa en Profundidad 5

3 Finalidad y Objetivos 6

3.1 Finalidad 6
3.2 Objetivos del Plan 6
3.2.1 Objetivo General 6
3.2.2 Objetivos Específicos 6

4 Alcance del Plan 8

4.1 Comunidad y Personal Universitario 8
4.2 Infraestructura de Servidores y Data Center 8
4.3 Estaciones de Trabajo y Dispositivos Finales 8
4.4 Infraestructura de Comunicaciones y Redes 8
4.5 Plataformas, Sistemas y Datos Institucionales. 9

5 Inventario y Clasificación de Activos 10

5.1 Procedimiento de Descubrimiento de Activos. 10
5.2 Categorización de Recursos por Nivel de Criticidad 10
5.3 Matriz Consolidada de Activos Tecnológicos de la UNAP 11

6 Análisis de Amenazas mediante STRIDE 12

6.1 Sistema Seleccionado y Definición Arquitectónica (DFD) 12
6.2 Identificación de Componentes y Límites de Confianza 12
6.3 Análisis de las Seis Categorías STRIDE (Hallazgos Reales) 12
6.4 Matriz STRIDE del Sistema de Matrícula 13

7 Inteligencia de Amenazas (Threat Intelligence) 14

7.1 Fuentes y Vectores de Vigilancia . . . 14
7.2 Procedimiento de Gestión de Inteligencia . . . 14
7.3 Producto de la Sección: Boletín de Inteligencia de Amenazas . . . 14

8 Análisis con MITRE ATT&CK 16

8.1 Estudio de TTPs Aplicables a la Superficie de la UNAP . . . 16
8.2 Matriz MITRE ATT&CK Institucional y Brechas de Visibilidad . . . 17
8.3 Regla de Detección SIEM (Wazuh / Sysmon) . . . 17

9 Análisis mediante Cyber Kill Chain 19

9.1 Modelado del Ciclo Lineal de Intrusión . . . 19
9.2 Puntos de Quiebre Defensivo y Controles de Interrupción . . . 19

10 Implementación de Arquitectura Zero Trust 21

10.1 Pilares de la Arquitectura Zero Trust en la UNAP . . . 21
10.2 Matriz de Roles, Usuarios y Permisos (RBAC / Zero Trust) . . . 21

11 Marco General de Ciberseguridad NIST CSF 2.0 23

11.1 Las Seis Funciones Fundamentales del NIST CSF 2.0 en la UNAP . . . 23
11.2 Matriz NIST CSF 2.0 de la UNAP . . . 23

12 Controles Técnicos de Seguridad 25

12.1 Catálogo de Especificación Técnica de Controles . . . 25
12.2 Configuración de Endurecimiento Web en Servidores Nginx . . . 25

13 Gestión y Respuesta a Incidentes 27

13.1 Procedimiento Operativo Estándar . . . 27
13.2 Canales Institucionales de Notificación Rápida . . . 27
13.3 Clasificación de Incidentes por Tipo de Amenaza . . . 28

14 Capacitación y Concientización 29

14.1 Campaña Permanente de Concientización . . . 29
14.2 Simulaciones Semestrales de Phishing Controlado . . . 29
14.3 Módulos de Formación Especializada para Personal Técnico . . . 29

15 Indicadores de Cumplimiento (Métricas y KPIs) 30

15.1 Cuadro de Mando de Métricas de Ciberseguridad . . . 30

Anexos: Evidencias y Documentación de Soporte 31

DECLARACIÓN ÉTICA, MARCO LEGAL Y METODOLOGÍA

Sección Preliminar: Marco de Integración Metodológica Institucional

NIST CSF 2.0 (Gestión) $\longrightarrow$ **STRIDE** (Amenazas) $\longrightarrow$ **MITRE ATT&CK** (TTPs)
$\longrightarrow$ **Threat Intelligence** (Vigilancia) $\longrightarrow$ **Cyber Kill Chain** (Fases) $\longrightarrow$ **Zero Trust** (Controles)

1 Declaración Ética y de No Intrusión

El presente documento, titulado **"Plan de Ciberseguridad Institucional de la Universidad Nacional del Altiplano de Puno (UNAP)"**, ha sido formulado exclusivamente con fines de investigación académica, auditoría defensiva (*Blue Team*) y diseño de arquitectura de seguridad (*Security by Design*).

Los autores/evaluadores declaran bajo juramento de integridad profesional y académica:

- **Ausencia de Pruebas Intrusivas:** En ninguna etapa de la elaboración de este plan se llevaron a cabo análisis de penetración activos (*Pentesting*), pruebas de denegación de servicio (DoS/DDoS), inyecciones de código malicioso, ataques de fuerza bruta contra paneles autenticados, ni explotación de vulnerabilidades en los sistemas de información institucionales.
- **Preservación de la Continuidad Operativa:** Ninguna de las consultas realizadas generó alteración, interrupción, degradación de rendimiento o indisponibilidad en los servicios informáticos de la UNAP.
- **Respeto a la Privacidad de los Datos:** No se accedió, extrajo, manipuló ni divulgó información personal, financiera o académica protegida perteneciente a estudiantes, docentes, personal administrativo o autoridades de la universidad. El acceso a las interfaces analizadas se efectuó dentro del marco de sesiones ordinarias y legítimas provistas a los miembros de la comunidad universitaria.
- **Finalidad Propositiva y Mitigadora:** Los hallazgos y evidencias recopilados tienen el único propósito de justificar técnicamente la necesidad de implementar controles preventivos bajo el marco NIST CSF 2.0, mitigar amenazas modeladas con STRIDE, mapear tácticas adversarias en MITRE ATT&CK e implementar un modelo de Confianza Cero (*Zero Trust*) que eleve la postura de ciberseguridad de la UNAP.

2 Marco Legal Aplicable en el Estado Peruano

El desarrollo de este plan y la justificación de los controles técnicos se fundamentan en el marco normativo nacional vigente en materia de gobernanza digital, seguridad de la información y delitos informáticos:

- **Ley N° 30096 (Ley de Delitos Informáticos) y su modificatoria Ley N° 30171:** La metodología empleada respeta irrestrictamente los artículos referidos al acceso ilícito (Art. 2), atentado a la integridad de datos y sistemas informáticos (Arts. 3 y 4) y fraude informático (Art. 8). Al no existir intrusión ni vulneración de medidas de seguridad perimetral, la recolección de telemetría pasiva no transgrede esta ley.
- **Decreto de Urgencia N° 006-2020 (Decreto de Urgencia que crea el Sistema Nacional de Transformación Digital):** Establece como deber de todas las entidades públicas peruanas, incluidas las universidades nacionales, la implementación de un Marco de Seguridad y Confianza Digital que proteja los activos de información del Estado.
- **Decreto Supremo N° 029-2021-PCM (Reglamento del Decreto Legislativo N° 1412, Ley de Gobierno Digital):** Dispone lineamientos mandatorios para la gestión de riesgos de seguridad digital en las plataformas de servicios digitales públicos.
- **Ley N° 29733 (Ley de Protección de Datos Personales) y su Reglamento (D.S. N° 003-2013-JUS):** Regula el tratamiento y la confidencialidad de los bancos de datos que albergan identificadores personales de estudiantes y trabajadores en los sistemas de matrícula y recursos humanos de la UNAP.
- **Resoluciones y Directivas de la Secretaría de Gobierno y Transformación Digital (SGTD - PCM):** En su calidad de ente rector nacional en ciberseguridad y coordinador del Centro Nacional de Seguridad Digital (CSIRT Nacional).

3 Metodología de Evaluación y Recolección de Evidencias

Para la identificación de brechas y sustento del análisis de amenazas, se utilizó estrictamente una metodología de evaluación pasiva de fuentes abiertas (OSINT) e inspección de cliente en comunicaciones estándar, desglosada en los siguientes procedimientos:

A Inteligencia de Fuentes Abiertas y Consulta DNS Pasiva (OSINT)

- **Descubrimiento de Superficie Expuesta:** Se consultaron los registros públicos de Transparencia de Certificados SSL/TLS (*Certificate Transparency Logs* vía `crt.sh`), identificando la existencia de más de un centenar de subdominios registrados bajo la zona `*.unap.edu.pe` sin interactuar directamente con los hosts objetivo.
- **Auditoría de Registros de Correo Institucional:** Se ejecutaron peticiones estándar de resolución de nombres DNS (tipo TXT) mediante la herramienta de diagnóstico de sistemas operativos `nslookup` apuntando a servidores DNS públicos, con el fin de evaluar la postura de los registros de autenticación de correo:
  - Verificación de la directiva SPF (*Sender Policy Framework*) en el dominio raíz `unap.edu.pe`.
  - Verificación de la presencia o ausencia de políticas de alineación DMARC (*Domain-based Message Authentication, Reporting, and Conformance*) en el nodo `_dmarc.unap.edu.pe`.

B Inspección Pasiva del Lado del Cliente (Client-Side Inspection)

- **Análisis de Cabeceras HTTP de Respuesta:** Mediante las herramientas de desarrollo web del navegador (DevTools - F12 / RFC 7230) en el marco de una navegación regular autorizada hacia los portales `https://matricula.unap.edu.pe` y `https://campus.unap.edu.pe`, se examinaron los encabezados enviados de forma pública por los servidores web:
  - Exposición de metadatos de software y versión en el encabezado `Server` (`nginx/1.16.1`).
  - Comprobación del estado de la directiva de transporte seguro HSTS (`Strict-Transport-Security`).
  - Inspección de cabeceras de defensa contra ataques visuales y de contexto (`X-Frame-Options`, `Content-Security-Policy`, `X-Content-Type-Options`).
- **Inspección de Atributos de Almacenamiento de Sesión:** Revisión de las banderas de seguridad asignadas a las cookies de autenticación generadas por el entorno de desarrollo (.NET Core: `.AspNetCore.Cookies`, `CookieTempDataProvider`) para evaluar la presencia de los atributos `HttpOnly`, `Secure` y `SameSite`.

C Modelado de Amenazas y Simulación Teórica (Tabletop Simulation)

La articulación de las amenazas no provino de incidentes forzados en producción, sino del cruce sistemático entre las vulnerabilidades de configuración verificadas pasivamente y las matrices estandarizadas de la industria (STRIDE de Microsoft, la taxonomía de técnicas de MITRE ATT&CK Enterprise v14 y las 7 fases de intrusión de la Cyber Kill Chain de Lockheed Martin).

Nota de Rigor Académico: Con este marco queda formalmente establecida la rigurosidad técnica, ética y legal del documento frente a cualquier comisión evaluadora o autoridad universitaria.

1 DATOS GENERALES DE LA ENTIDAD

En este capítulo se especifican los datos formales de la institución universitaria, las unidades de gobierno responsables de la ejecución del plan de seguridad digital y su periodo de vigencia.

Sec 1.1 Ficha Técnica Institucional

Campo	Detalle Institucional
Nombre de la Entidad	Universidad Nacional del Altiplano de Puno (UNAP)
Tipo de Institución	Universidad Pública del Estado Peruano
Unidad Responsable	Oficina de Tecnologías de la Información (OTI) / Unidad de Seguridad y Redes
Responsable del Plan	Jefe de la OTI / Oficial de Seguridad de la Información (CISO institucional)
Periodo de Vigencia	2026 – 2027
Fecha de Aprobación	Conforme a resolución rectoral institucional
Ámbito de Aplicación	Campus universitario central (Av. Floral N° 1153, Puno), dependencias administrativas, facultades, escuelas profesionales, laboratorios y centros de producción e investigación

Sec 1.2 Estructura Orgánica y Roles de Seguridad

La ejecución y supervisión del presente plan involucra a los siguientes actores de la gobernanza universitaria:

1. **Alta Dirección (Rectorado y Vicerrectorados):** Aprobación presupuestal, respaldo normativo y asignación de prioridades para el fortalecimiento de la infraestructura digital.
2. **Oficina de Tecnologías de la Información (OTI):** Conducción técnica, administración del Data Center institucional y despliegue de las políticas de seguridad.
3. **Unidad de Seguridad y Redes / CSIRT-UNAP:** Monitoreo continuo de eventos, gestión de firewalls, sistemas de detección y respuesta inmediata a incidentes.

2 INTRODUCCIÓN

La gestión de la ciberseguridad en el sector universitario contemporáneo exige equilibrar la apertura para la investigación académica con la protección rigurosa de las plataformas tecnológicas.

Sec 2.1 Contexto y Relevancia Institucional

La salvaguarda del ecosistema digital de la Universidad Nacional del Altiplano de Puno (UNAP) constituye un pilar esencial para la continuidad de los servicios educativos, la integridad de los registros académicos oficiales y la protección de los datos personales de miles de estudiantes, docentes y administrativos.

Sec 2.2 Caracterización de la Superficie Expuesta Universitaria

El análisis preliminar de la infraestructura expuesta de la UNAP evidencia una topología amplia y heterogénea:

- **Más de 100 subdominios públicos indexados:** Identificados en servidores de nombres autoritativos y registros de transparencia de certificados SSL (`crt.sh`).
- **Coexistencia de plataformas críticas:** Servicios esenciales de alta transaccionalidad como el Sistema de Matrícula (`matricula.unap.edu.pe`) y el Campus Virtual Moodle (`campus.unap.edu.pe`).
- **Exposición de entornos legados y de desarrollo:** Presencia pública de subdominios de prueba, servidores de desarrollo y paneles administrativos desactualizados (tales como `dev.*`, `pruel.*`, `cpanel.*`), los cuales carecen de controles perimetrales homogéneos y representan puntos de entrada de alto riesgo.

Sec 2.3 Transición hacia un Modelo de Defensa en Profundidad

El modelo de seguridad perimetral tradicional (basado exclusivamente en un firewall de borde) resulta insuficiente frente a amenazas modernas como el ransomware, el spear-phishing y la exfiltración dirigida. Se justifica plenamente la adopción de un esquema de **Defensa en Profundidad** (*Defense in Depth*) articulado con una arquitectura **Zero Trust**, garantizando visibilidad y control estricto en cada capa tecnológica.

3 FINALIDAD Y OBJETIVOS

En este capítulo se define el propósito estratégico del plan de seguridad digital y los objetivos medibles formulados para la UNAP.

Sec 3.1 Finalidad

Establecer medidas técnicas, tácticas y organizacionales para prevenir, detectar, responder y recuperarse oportunamente ante incidentes de ciberseguridad, articulando armónicamente las metodologías **STRIDE**, **Threat Intelligence**, **MITRE ATT&CK**, **Cyber Kill Chain** y los principios de la arquitectura **Zero Trust**, todo ello bajo la gobernanza y directrices estructurales de **NIST CSF 2.0**.

Sec 3.2 Objetivos del Plan

3.2.1 Objetivo General

Fortalecer la resiliencia operativa y la seguridad de la información de la Universidad Nacional del Altiplano de Puno mediante la catalogación de activos críticos, el modelado formal de amenazas, la aplicación de controles de mínimo privilegio y el establecimiento de protocolos de detección y respuesta continua.

3.2.2 Objetivos Específicos

1. **Inventariar y clasificar:** Identificar y categorizar integralmente el inventario de recursos y activos tecnológicos de la institución según su criticidad.

2. **Modelar amenazas web:** Determinar vulnerabilidades y vectores de amenaza en los servicios web académicos esenciales mediante la metodología STRIDE.

3. **Caracterizar TTPs adversarias:** Mapear las tácticas, técnicas y procedimientos de potenciales atacantes empleando la matriz MITRE ATT&CK.

4. **Vigilancia proactiva:** Detectar indicadores de compromiso (IoCs) y campañas dirigidas mediante capacidades de Threat Intelligence.

5. **Fortalecer controles preventivos:** Implementar controles perimetrales y de aplicación robustos (WAF, HSTS forzado, EDR centralizado).

6. **Gobierno de identidades Zero Trust:** Desplegar esquemas de autenticación multifactor (MFA) y verificación explícita para docentes y personal administrativo.

7. **Garantizar la privacidad de datos:** Mitigar los riesgos de impacto sobre la privacidad y confidencialidad de la información estudiantil y docente conforme a la Ley N° 29733.

8. **Estandarizar la respuesta a incidentes:** Formalizar la operación y protocolos del Equipo de Respuesta a Incidentes de Seguridad de la UNAP (CSIRT-UNAP).

4 ALCANCE DEL PLAN

El alcance del presente plan abarca formalmente a todos los estamentos, infraestructuras, plataformas y dependencias que conforman el ecosistema tecnológico de la Universidad Nacional del Altiplano.

Sec 4.1 Comunidad y Personal Universitario

- Personal Docente (ordinarios y contratados).
- Personal Administrativo y directivo.
- Comunidad Estudiantil de pregrado y posgrado.
- Personal de servicios, terceros y contratistas con acceso a recursos institucionales.

Sec 4.2 Infraestructura de Servidores y Data Center

- Servidores físicos y clústeres de virtualización alojados en el Data Center central de la OTI.
- Ambientes de producción, pruebas y contingencia en sistemas operativos Linux y Windows Server.
- Sistemas de almacenamiento centralizado (NAS / SAN) y nodos de cómputo.

Sec 4.3 Estaciones de Trabajo y Dispositivos Finales

- Computadoras de escritorio y portátiles en oficinas administrativas y decanatos.
- Equipos en laboratorios de cómputo de las distintas facultades y escuelas profesionales.
- Dispositivos móviles institucionales y acceso remoto de usuarios autorizados.

Sec 4.4 Infraestructura de Comunicaciones y Redes

- Switches de distribución y Switch Core central.

- Segmentación lógica de redes mediante VLANs.
- Infraestructura de red inalámbrica (Wi-Fi de campus para alumnos, docentes y administrativos).
- Enlaces de conectividad WAN e interfaces de conexión hacia la Red Dorsal y proveedores de Internet (ISP).

Sec 4.5 Plataformas, Sistemas y Datos Institucionales

- **Aplicaciones y portales web institucionales:** Sistema de Matrícula (`matricula.unap.edu.pe`), Campus Virtual (`campus.unap.edu.pe`), SITRAD (Trámite Documentario), Pasarela de Recaudación y pagos.
- **Bases de datos:** Repositorios centrales de notas, registros de tesorería, planillas de personal y expedientes estudiantiles.
- **Servicios de comunicación institucional:** Servicio de correo electrónico institucional (`@unap.edu.pe`), repositorios digitales (DSpace) y servicios en la nube.
- **Proveedores y contratistas:** Servicios tercerizados de desarrollo de software, mantenimiento de telecomunicaciones y soporte de infraestructura.

5 INVENTARIO Y CLASIFICACIÓN DE ACTIVOS

La correcta identificación y categorización de los activos informáticos es la base fundamental para determinar la superficie de exposición y focalizar los controles de seguridad.

Sec 5.1 Procedimiento de Descubrimiento de Activos

Para identificar los activos tecnológicos expuestos sin alterar la operatividad de los servidores universitarios, se aplicó un procedimiento pasivo de recolección en fuentes abiertas:

1. **Inspección de Registros de Transparencia de Certificados SSL (crt.sh):** Búsqueda sistemática de certificados emitidos para la raíz `unap.edu.pe`, permitiendo descubrir subdominios históricos y activos.
2. **Consultas de Infraestructura DNS:** Verificación de registros autoritativos `A`, `CNAME`, `NS` y `MX` para trazar la infraestructura de direccionamiento IP y servidores de nombres.
3. **Identificación de Servicios Expuestos:** Mapeo de tecnologías de frontend y backend asociadas a los nombres de dominio descubiertos.

Sec 5.2 Categorización de Recursos por Nivel de Criticidad

Los activos descubiertos se agrupan en cuatro niveles de criticidad conforme a su impacto en la operación y en la privacidad de datos:

- **Nivel Crítico:**
  - Base de Datos Académica Central (PostgreSQL / Oracle).
  - Portal y API del Sistema de Matrícula (`matricula.unap.edu.pe`).
  - Campus Virtual Institucional Moodle (`campus.unap.edu.pe`).
  - Switch Core central del Data Center OTI.
- **Nivel Alto:**
  - Servicio de Correo Institucional (`@unap.edu.pe`).
  - Sistema de Trámite Documentario (SITRAD).
  - Sistemas financieros de tesorería, cobranza y planillas de remuneraciones.

- **Nivel Medio:**
  - Repositorio Institucional Digital (DSpace).
  - Portales web informativos de facultades y direcciones universitarias.
- **Nivel Bajo:**
  - Sitios web estáticos, páginas de eventos pasados y blogs informativos.

Sec 5.3 Matriz Consolidada de Activos Tecnológicos de la UNAP

A continuación, se presenta la matriz representativa de los principales activos evaluados:

ID	Nombre del Activo	Identificador / URL	Función Principal	Criticidad
ACT-01	BD Académica Central	Servidor de BD Data Center	Almacenamiento central de notas y actas	**Crítico**
ACT-02	Sistema de Matrícula	`matricula.unap.edu.pe`	Inscripción y carga horaria estudiantil	**Crítico**
ACT-03	Campus Virtual (LMS)	`campus.unap.edu.pe`	Docencia virtual, foros y evaluaciones	**Crítico**
ACT-04	Switch Core de Red	Data Center OTI	Enrutamiento y conmutación de tráfico	**Crítico**
ACT-05	Correo Institucional	`mail.unap.edu.pe`	Comunicaciones oficiales y notificaciones	**Alto**
ACT-06	SITRAD	`sitrad.unap.edu.pe`	Trámite documentario y resoluciones	**Alto**
ACT-07	Repositorio DSpace	`repositorio.unap.edu.pe`	Publicación de tesis e investigaciones	**Medio**
ACT-08	Portales de Facultades	`fimees.unap.edu.pe/*`	Difusión académica e institucional	**Medio**
ACT-09	Subdominios Legados/Dev	`dev.*/prue1.*`	Ambientes de prueba sin mantenimiento	**Alto (Riesgo)**

6 ANÁLISIS DE AMENAZAS MEDIANTE STRIDE

En este capítulo se aplica el modelado formal de amenazas de Microsoft (STRIDE) sobre el sistema más crítico de la universidad.

Sec 6.1 Sistema Seleccionado y Definición Arquitectónica (DFD)

El análisis se focaliza en el **Portal y API del Sistema de Matrícula** (`https://matricula.unap.edu.pe`), responsable del procesamiento masivo de datos académicos y personales.
Diagrama de Flujo de Datos (DFD Nivel 1):

$$\textbf{[Navegador Cliente]} \xleftrightarrow{\text{HTTPS / TLS}} \textbf{[Reverse Proxy Nginx]} \xleftrightarrow{\text{HTTP}} \textbf{[Backend ASP.NET Core]} \xleftrightarrow{\text{TCP / SQL}} \textbf{[Base de Datos]}$$

Sec 6.2 Identificación de Componentes y Límites de Confianza

- **Límite de Confianza 1 (Internet ↔ Proxy Inverso):** Cruza la frontera entre las redes externas no confiables y el DMZ universitario.
- **Límite de Confianza 2 (Proxy Inverso ↔ Backend ASP.NET Core):** Comunica el balanceador/proxy con los servidores de aplicaciones internos.
- **Límite de Confianza 3 (Backend ↔ Base de Datos):** Conecta la lógica de negocio con el repositorio de datos de estudiantes y actas.

Sec 6.3 Análisis de las Seis Categorías STRIDE (Hallazgos Reales)

Al contrastar la arquitectura y las evidencias recopiladas con las 6 categorías de STRIDE, se identificaron los siguientes hallazgos:

1. **S (Spoofing - Suplantación de Identidad):** Ausencia de autenticación multifactor (MFA) obligatoria en el acceso de docentes y alumnos, junto con debilidad en el manejo de cookies de sesión temporales, lo que facilita el secuestro de sesiones.
2. **T (Tampering - Alteración de Información):** Riesgo de ataques Man-in-the-Middle y alteración del tráfico web debido a la ausencia de la cabecera HSTS (`Strict-Transport-Security: Desactivado`), permitiendo ataques de degradación de SSL (SSL Stripping).

3. **R (Repudiation - Repudio):** Carencia de registros de auditoría centralizados e inmutables que certifiquen de manera fehaciente las modificaciones de matrículas, retiro de asignaturas o rectificación de notas.

4. **I (Information Disclosure - Fuga de Información):** Exposición explícita de tecnologías y versiones desactualizadas en cabeceras de respuesta HTTP públicas (ej. cabecera observada `Server: nginx/1.16.1`), lo que brinda a atacantes vectores conocidos de explotación.

5. **D (Denial of Service - Denegación de Servicio):** Susceptibilidad ante picos masivos de concurrencia simultánea en ventanas de matrícula sin mecanismos de rate-limiting en WAF ni balanceo elástico de carga.

6. **E (Elevation of Privilege - Escalada de Privilegios):** Riesgo de manipulación de parámetros de rol e identificadores de usuario (vulnerabilidades IDOR) en endpoints de la API REST interna (ej. rutas como `/matricula/alumno/*`).

Sec 6.4 Matriz STRIDE del Sistema de Matrícula

Cat.	Vector de Amenaza	Hallazgo Específico	Impacto Potencial	Control de Remediación
S	Spoofing	Credenciales de usuario único sin MFA y cookies vulnerables	Suplantación de identidad de estudiantes/docentes	Despliegue de MFA (TOTP) y banderas `Secure; HttpOnly; SameSite`
T	Tampering	Ausencia de cabecera HSTS en el servidor web	Intercepción y alteración de tráfico en tránsito	HSTS forzado con `max-age=31536000; includeSubDomains`
R	Repudiation	Logs locales sin firma digital ni inmutabilidad	Imposibilidad de determinar autoría en cambios	Centralización de logs de auditoría en SIEM con timestamping
I	Info Disclosure	Exposición de versión en cabecera `Server: nginx/1.16.1`	Fingerprinting y selección de exploits específicos	Ocultamiento de versiones con `server_tokens off;`
D	Denial of Service	Saturación de conexiones HTTP en días de matrícula	Indisponibilidad del servicio de matrícula	Configurar WAF perimetral y directivas `limit_req` en Nginx
E	Elevation of Priv.	Parámetros manipulables en API REST (`/matricula/alumno/*`)	Escalada horizontal o acceso a expedientes ajenos	Validación estricta de autorización y tokens JWT por rol

7 INTELIGENCIA DE AMENAZAS (THREAT INTELLIGENCE)

En este capítulo se estructura el modelo de vigilancia activa de amenazas para anticipar ataques dirigidos contra el entorno universitario.

Sec 7.1 Fuentes y Vectores de Vigilancia

El programa de Inteligencia de Amenazas de la UNAP se enfoca en el monitoreo continuo de los siguientes riesgos críticos:

- **Phishing de Credenciales Institucionales:** Campañas dirigidas a capturar cuentas de correo `@unap.edu.pe` y accesos a matrícula.
- **Dominios Tipográficos (Typosquatting):** Detección temprana de registros maliciosos que imitan los portales oficiales (ej. dominios apócrifos como `unap-matricula.*`, `unap-portal.*`).
- **Vulnerabilidades y Exploits Conocidos:** Alertas sobre fallos que afectan al stack tecnológico observado, en especial exploits dirigidos a `Nginx 1.16.1` y componentes web legados.
- **Fuentes de Información Especializadas:** Monitoreo de feeds del CSIRT Nacional (Perú), catálogo CISA KEV (Known Exploited Vulnerabilities) y comunidades globales de inteligencia (AlienVault OTX).

Sec 7.2 Procedimiento de Gestión de Inteligencia

El flujo operativo para transformar datos de amenazas en contramedidas defensivas sigue un ciclo de 6 etapas:

Recopilación $\longrightarrow$ Correlación Logs $\longrightarrow$ Clasificación Criticidad $\longrightarrow$ Generación IoCs $\longrightarrow$ Actualización WAF $\longrightarrow$ Comunicación Interna

1. **Recopilación:** Captura de feeds de IoCs (direcciones IP maliciosas, hashes de malware, dominios fraudulentos).
2. **Correlación de Logs:** Búsqueda retrospectiva en la plataforma SIEM para verificar si los IoCs tuvieron contacto con la red interna.
3. **Clasificación de Criticidad:** Evaluación del impacto potencial de la amenaza reportada sobre los activos de la UNAP.
4. **Generación de IoCs:** Creación de firmas y listas negras institucionales.
5. **Actualización en Firewall/WAF:** Ingesta automática de bloqueos en el firewall perimetral y reglas del WAF.
6. **Comunicación Interna:** Emisión de alertas tempranas y boletines preventivos dirigidos a los usuarios.

Sec 7.3 Producto de la Sección: Boletín de Inteligencia de Amenazas

>_ | Boletín de Inteligencia de Amenazas: Alerta Spear-Phishing y Suplantación

```
[ALERTA DE SEGURIDAD DIGITAL - CSIRT-UNAP / OTI]
Codigo de Alerta: ALERTA-TI-2026-004
Nivel de Severidad: ALTO (CVSS: 7.8)
Fecha de Emision: 17 de Octubre de 2026

AMENAZA DETECTADA:
Campana de Spear-Phishing dirigida a docentes y alumnos mediante dominios de
typosquatting que emulan el sistema oficial de matricula (ej. inap-matricula.
    com).

INDICADORES DE COMPROMISO (IoCs):
* Dominios detectados: unap-matricula.online, portal-unap.org
* IPs de origen C2: 198.51.100.45, 203.0.113.88
* Asunto de correos fraudulentos: 'URGENTE: Actualizacion de Datos Matricula
    2026-I'

ACCIONES PREVENTIVAS EJECUTADAS:
1. Bloqueo de dominios e IPs en Firewall de borde y servidores DNS internos.
2. Ingesta de reglas de deteccion en Wazuh SIEM para correlacionar accesos.
3. Notificacion a los administradores de correo para aislamiento de mensajes.
```

8 ANÁLISIS CON MITRE ATT&CK

Para caracterizar el comportamiento táctico de los adversarios, se utiliza la matriz **MITRE ATT&CK for Enterprise**, permitiendo identificar brechas de visibilidad e implementar reglas de detección precisas.

Sec 8.1 Estudio de TTPs Aplicables a la Superficie de la UNAP

A continuación, se describen las Tácticas, Técnicas y Procedimientos (TTPs) más relevantes para la infraestructura evaluada:

- **Reconocimiento (TA0043):**
  - **T1596 (Search Open Technical Databases):** Identificación de subdominios y certificados mediante plataformas públicas como `crt.sh`.
  - **T1589 (Gather Victim Identity Info):** Recolección de correos institucionales de autoridades y docentes desde la web institucional.
- **Acceso Inicial (TA0001):**
  - **T1566.002 (Spearphishing Link):** Envío de enlaces maliciosos simulando comunicaciones del rectorado o la OTI.
  - **T1078 (Valid Accounts):** Acceso a plataformas universitarias utilizando credenciales legítimas comprometidas sin factor MFA.
- **Ejecución (TA0002):**
  - **T1059 (Command and Scripting Interpreter):** Ejecución no autorizada de comandos en el intérprete del servidor web a través de vulnerabilidades de aplicación.
- **Persistencia (TA0003):**
  - **T1505.003 (Web Shell):** Carga de archivos maliciosos en directorios de carga (*uploads*) del Campus Virtual o portales web.
- **Escalada de Privilegios (TA0004):**
  - **T1068 (Exploitation for Privilege Escalation):** Aprovechamiento de fallos en versiones desactualizadas de software base (ej. servidores web Nginx o kernels Linux).
- **Descubrimiento (TA0007):**
  - **T1046 (Network Service Discovery):** Escaneo de puertos y servicios internos lanzado desde estaciones de cómputo o laboratorios de alumnos.
- **Movimiento Lateral (TA0008):**
  - **T1021.002 (SMB Shares):** Propagación entre estaciones de trabajo administrativas mediante carpetas compartidas sin segmentar.
- **Exfiltración (TA0010):**
  - **T1048 (Exfiltration Over Alternative Protocol):** Salida de bases de datos o información confidencial mediante canales web cifrados o protocolos no supervisados.

Sec 8.2 Matriz MITRE ATT&CK Institucional y Brechas de Visibilidad

Táctica MITRE	Técnica / ID	Escenario en la UNAP	Control / Brecha de Visibilidad
Reconocimiento	T1596 / T1589	Rastreo pasivo en crt.sh y directorio docente	Brecha: Información expuesta públicamente
Acceso Inicial	T1566.002 / T1078	Phishing con enlaces apócrifos y cuentas sin MFA	Control: Despliegue de MFA y filtrado de correo
Ejecución	T1059	Ejecución de scripts en servidores web vulnerables	Control: Restricción de permisos y WAF
Persistencia	T1505.003	Carga de Web Shell en formularios sin sanitizar	Brecha: Carencia de monitoreo de integridad FIM
Escalada Priv.	T1068	Exploits en Nginx 1.16.1 o Linux legados	Control: Gestión y parcheo de vulnerabilidades
Descubrimiento	T1046	Escaneo de red interna desde laboratorios estudiantiles	Brecha: Falta de microsegmentación entre VLANs
Mov. Lateral	T1021.002	Movimiento vía SMB en redes de oficinas	Control: Deshabilitar SMBv1 y aislar puestos
Exfiltración	T1048	Extracción de tablas de notas vía HTTPS no filtrado	Control: Inspección TLS y DLP perimetral

Sec 8.3 Regla de Detección SIEM (Wazuh / Sysmon)

Para mitigar la técnica de ejecución y persistencia (T1505.003 - Web Shell), se define la siguiente regla de correlación:

>_ | Regla Wazuh para Detección de Creación de Web Shell (/etc/rules/local_rules.xml)

```
<group name='web,attack,'>
  <rule id='100250' level='12'>
    <if_group>syscheck</if_group>
    <match>/var/www/html/uploads/</match>
    <description>Alerta Critica: Creacion de archivo ejecutable (.php) en
   carpeta uploads</description>
```

```
    <mitre>
      <id>T1505.003</id>
    </mitre>
  </rule>
</group>
```

9 ANÁLISIS MEDIANTE CYBER KILL CHAIN

En este capítulo se modela el ciclo de intrusión lineal que un adversario ejecutaría contra el sistema académico y personal de la UNAP, determinando los puntos de interrupción defensiva.

Sec 9.1 Modelado del Ciclo Lineal de Intrusión

El escenario reconstruye un vector de intrusión dirigido hacia el personal docente y la plataforma académica:

1. **Reconocimiento (Reconnaissance):** Mapeo pasivo de subdominios universitarios (`matricula.unap.edu.pe`) y extracción de nombres y correos de directores de escuela y docentes mediante fuentes abiertas (OSINT).
2. **Armamento (Weaponization):** Clonación visual fidedigna del formulario de inicio de sesión de `matricula.unap.edu.pe` montado en un servidor externo bajo dominio tipográfico.
3. **Entrega (Delivery):** Envío masivo de correos electrónicos fraudulentos suplantando al Vicerrectorado Académico, aprovechando la **ausencia de registro DMARC (NXDOMAIN)** y un registro **SPF excesivamente permisivo** (`~all` SoftFail) en el dominio institucional `unap.edu.pe`.
4. **Explotación (Exploitation):** El docente o alumno hace clic en el enlace malicioso e introduce sus credenciales oficiales en la página clonada apócrifa.
5. **Instalación (Installation):** El atacante captura las credenciales válidas y accede directamente a las plataformas institucionales internas sin requerimiento de segundo factor (MFA).
6. **Comando y Control (C2):** Establecimiento de túneles y sesiones interactivas cifradas HTTPS hacia el exterior que pasan desapercibidas por carecer de inspección TLS profunda.
7. **Acción sobre el Objetivo (Actions on Objectives):** Alteración de calificaciones en actas, reserva irregular de vacantes o exfiltración de tablas con información personal sensible.

Sec 9.2 Puntos de Quiebre Defensivo y Controles de Interrupción

El principio fundamental de la Cyber Kill Chain establece que neutralizar cualquier fase interrumpe la consumación del ataque:

Fase Kill Chain	Acción del Adversario en UNAP	Control Preventivo / Detectivo de Ruptura
1. Reconocimiento	Rastreo de subdominios y correos	Vigilancia OSINT, reducción de huella digital y monitoreo DNS
2. Armamento	Montaje de web clonada de matrícula	Detección temprana de typosquatting vía Threat Intelligence

Fase Kill Chain	Acción del Adversario en UNAP	Control Preventivo / Detectivo de Ruptura
3. Entrega	Envío de correo apócrifo de la UNAP	Publicación de registro DMARC estricto (`p=reject`) y SPF con `-all`
4. Explotación	Clic en enlace apócrifo de correo	Filtrado web en endpoints y concientización antispam en usuarios
5. Instalación	Inicio de sesión con credencial robada	Autenticación Multifactor obligatoria (MFA/TOTP) que bloquea el acceso
6. C2	Túnel HTTPS saliente no filtrado	Inspección profunda SSL/TLS en firewall NGFW y bloqueo de IPs C2
7. Objetivos	Extracción y alteración de notas	Control RBAC estricto, inmutabilidad de actas y alertas SIEM

>_ | Evidencia Técnica DNS: Ausencia de DMARC y SPF Permisivo

```
# Consulta de registro DMARC en el dominio institucional
$ dig _dmarc.unap.edu.pe TXT +short
;; Got SERVFAIL or NXDOMAIN (Registro DMARC inexistente)

# Consulta de registro SPF en unap.edu.pe
$ dig unap.edu.pe TXT +short
'v=spf1 ip4:161.132.24.0/24 include:_spf.google.com ~all'
# Diagnostico: El modificador ~all (SoftFail) permite suplantacion sin rechazo
    forzado
```

10 IMPLEMENTACIÓN DE ARQUITECTURA ZERO TRUST

En este capítulo se establece la estrategia de transición hacia un modelo Zero Trust, fundamentado en la premisa rectora:

> *"Nunca confiar automáticamente; verificar siempre de forma explícita y asumir la brecha".*

Sec 10.1 Pilares de la Arquitectura Zero Trust en la UNAP

La implementación abarca los cinco pilares esenciales de seguridad:

1. **Pilar Identidad:** Despliegue mandatorio de Autenticación Multifactor (MFA mediante TOTP o llaves FIDO2) para el 100 % de docentes y personal administrativo. Política rigurosa de depuración y eliminación de cuentas inactivas o egresadas.
2. **Pilar Dispositivos:** Verificación previa del estado de salud y cumplimiento del endpoint (*Device Compliance*) antes de permitir la conexión a servicios centrales o bases de datos de la universidad.
3. **Pilar Red (Microsegmentación):** Aislamiento estricto del tráfico de red a nivel de capa 3 mediante VLANs dedicadas con reglas de filtrado en Switch Core y Firewall:
   - VLAN 10: Servidores de Producción y Data Center (restringida).
   - VLAN 20: Personal Administrativo y Tesorería.
   - VLAN 30: Salas de Profesores y Docentes.
   - VLAN 40: Laboratorios de Cómputo para Estudiantes.
   - VLAN 50: Zona Desmilitarizada (DMZ) para servicios públicos.
   - VLAN 60: Wi-Fi para Invitados (aislamiento total de la red interna).
4. **Pilar Aplicaciones:** Inspección continua de tráfico web a través de un Web Application Firewall (WAF) perimetral, transición obligatoria hacia TLS 1.3 con desactivación de suites criptográficas heredadas y endurecimiento (*hardening*) del servidor Nginx.
5. **Pilar Datos:** Cifrado integral de bases de datos tanto en reposo (AES-256) como en tránsito (TLS 1.3), complementado con la aplicación estricta del principio de mínimo privilegio en el acceso a tablas.

Sec 10.2 Matriz de Roles, Usuarios y Permisos (RBAC / Zero Trust)

Rol Institucional	Identidades	Ámbito de Acceso Autorizado	Controles Obligatorios
Super Administrador	Personal OTI designado	Consolas de administración, Switch Core y servidores	MFA físico (FIDO2), acceso solo por IP estática y bastion host
Docente	Docentes ordinarios y contratados	Módulo docente del SIA y Campus Virtual institucional	MFA por TOTP, expiración de sesión a 15 min de inactividad
Estudiante	Alumnos matriculados	Consulta de notas, matrícula web y Campus Virtual	Credencial única, captcha y límite de intentos fallidos
Administrativo	Personal de tesorería y mesa de partes	SITRAD y sistemas de recaudación específicos	Acceso restringido a VLAN 20 y horario laboral institucional

11 MARCO GENERAL DE CIBERSEGURIDAD NIST CSF 2.0

En este capítulo se articula el gobierno de la ciberseguridad universitaria bajo el estándar internacional **NIST Cybersecurity Framework 2.0**, integrando sus seis funciones fundamentales.

Sec 11.1 Las Seis Funciones Fundamentales del NIST CSF 2.0 en la UNAP

1. **GOVERN (Gobernar):** Establecimiento y difusión de directivas institucionales de seguridad digital, designación formal del Oficial de Seguridad de la Información (CISO), asignación presupuestal específica y alineamiento con la normativa del Estado Peruano (D.U. N° 006-2020).
2. **IDENTIFY (Identificar):** Catalogación y actualización continua del inventario de activos, evaluación sistemática de riesgos informáticos y análisis de impacto en la operación académica universitaria.
3. **PROTECT (Proteger):** Hardening de servidores Nginx, publicación forzada de cabeceras HSTS, configuración de registros SPF estricto (`-all`) y DMARC (`p=reject`), y adopción de autenticación multifactor (MFA).
4. **DETECT (Detectar):** Monitoreo operacional 24/7 mediante la plataforma SIEM centralizada (Wazuh), correlación de anomalías, alertas automáticas por fuerza bruta y recolección inmutable de registros de eventos.
5. **RESPOND (Responder):** Protocolos y playbooks operativos para contención inmediata, aislamiento automático de subredes comprometidas y comunicación institucional con el CSIRT Nacional de la PCM.
6. **RECOVER (Recuperar):** Políticas de respaldo bajo el esquema 3-2-1 con copias de seguridad inmutables fuera de línea (*Air-Gapped*) y ensayos periódicos semestrales de restauración de bases de datos.

Sec 11.2 Matriz NIST CSF 2.0 de la UNAP

Función NIST	Acción Estratégica	Responsable	Herramientas / Controles
GOVERN	Políticas y directivas de seguridad	Rectorado / CISO	Comité de Gobierno Digital y normativas
IDENTIFY	Inventario continuo y matriz de riesgos	Unidad de Seguridad	crt.sh, Nessus y matriz de activos
PROTECT	Hardening web, MFA y DMARC	OTI / Redes	Nginx, Let's Encrypt, TOTP, DNS BIND

Función NIST	Acción Estratégica	Responsable	Herramientas / Controles
DETECT	Monitoreo continuo de eventos y logs	CSIRT-UNAP	Wazuh SIEM, Suricata IDS y Syslog
RESPOND	Playbooks de contención de incidentes	CSIRT-UNAP	Procedimientos formales y scripts de aislamiento
RECOVER	Restauración de respaldos 3-2-1	OTI / Soporte	Almacenamiento Air-Gapped y Veeam Backup

12 CONTROLES TÉCNICOS DE SEGURIDAD

En este capítulo se detallan las especificaciones técnicas y el catálogo de implementación de los controles de seguridad seleccionados para blindar el entorno tecnológico de la UNAP.

Sec 12.1 Catálogo de Especificación Técnica de Controles

1. **Control de Identidad y Acceso:** Implementación generalizada de Autenticación Multifactor (MFA) sobre un esquema de Inicio de Sesión Único (Single Sign-On - SSO) corporativo basado en OpenID Connect / SAML 2.0.

2. **Seguridad Perimetral y de Aplicación:** Despliegue de un Firewall de Siguiente Generación (Next-Generation Firewall - NGFW) en el borde y un Web Application Firewall (WAF) perimetral para inspección de peticiones HTTP/HTTPS (bloqueo de inyecciones SQL, XSS y ataques L7).

3. **Seguridad en Endpoints:** Instalación de agentes de Endpoint Detection and Response (EDR) centralizados en todas las estaciones administrativas y servidores del Data Center para detección de comportamientos anómalos.

4. **Cifrado Criptográfico Estricto:** Forzado del protocolo TLS 1.3 en todos los portales web institucionales, desactivación definitiva de suites criptográficas débiles (SSLv3, TLS 1.0, TLS 1.1) y cifrado de volúmenes de almacenamiento mediante LUKS / BitLocker.

5. **Monitoreo y Auditoría Centralizada:** Plataforma SIEM (Security Information and Event Management) basada en Wazuh para agregación, correlación y análisis de registros de eventos en tiempo real.

6. **Microsegmentación de Redes:** Reglas estrictas de filtrado de tráfico inter-VLAN en el Switch Core central, impidiendo que el tráfico de alumnos acceda a servidores de bases de datos o redes administrativas.

7. **Gestión Continua de Vulnerabilidades:** Ejecución de escaneos periódicos programados mediante OpenVAS / Nessus para identificación y remediación temprana de fallas en servidores y servicios expuestos.

8. **Continuidad Operativa y Respaldos Inmutables:** Automatización de copias de seguridad de bases de datos con retención histórica y almacenamiento inmutable fuera de línea.

Sec 12.2 Configuración de Endurecimiento Web en Servidores Nginx

A continuación, se presenta la directiva de configuración recomendada para mitigar los hallazgos de información expuesta y falta de HSTS:

>_ | Configuración Nginx para Hardening (security.conf)

```
# Desactivar version de servidor
server_tokens off;

# Cabeceras de proteccion obligatorias
add_header Strict-Transport-Security 'max-age=31536000; includeSubDomains'
    always;
add_header X-Frame-Options 'SAMEORIGIN' always;
add_header X-Content-Type-Options 'nosniff' always;
add_header X-XSS-Protection '1; mode=block' always;
add_header Content-Security-Policy 'default-src \'self\';' always;

# Forzar TLS 1.2 y 1.3 unicamente
ssl_protocols TLSv1.2 TLSv1.3;
ssl_prefer_server_ciphers on;
```

13 GESTIÓN Y RESPUESTA A INCIDENTES

En este capítulo se describe el procedimiento operativo estándar para la gestión, contención y recuperación ante eventos o incidentes de seguridad que afecten a la UNAP.

Sec 13.1 Procedimiento Operativo Estándar

El ciclo de vida de atención a incidentes de seguridad digital sigue la secuencia estándar de seis fases:

Detección $\longrightarrow$ Análisis y Triaje $\longrightarrow$ Contención
$\longrightarrow$ Erradicación $\longrightarrow$ Recuperación $\longrightarrow$ Evaluación Post-Mortem

1. **Detección:** Identificación de alertas a través del SIEM, reportes de usuarios o anomalías en el tráfico de red.
2. **Análisis y Triaje:** Determinación del alcance, impacto potencial y severidad del incidente por parte del equipo CSIRT-UNAP.
3. **Contención:** Aplicación de medidas de aislamiento inmediato (aislamiento de VLAN, revocación de tokens, bloqueo perimetral de IPs) para evitar la propagación.
4. **Erradicación:** Eliminación de artefactos maliciosos, cierre de brechas de configuración y revocación de credenciales comprometidas.
5. **Recuperación:** Restauración de servicios a partir de respaldos limpios validados y reactivación paulatina con monitoreo reforzado.
6. **Evaluación Posterior (Post-Mortem):** Elaboración del informe técnico final, identificación de lecciones aprendidas y ajuste de controles preventivos.

Sec 13.2 Canales Institucionales de Notificación Rápida

Para garantizar la oportuna recepción de reportes sobre comportamientos anómalos, se formalizan los siguientes canales oficiales:

- **Correo Electrónico de Seguridad:** `seguridad.informatica@unap.edu.pe`
- **Anexo Telefónico de Emergencia OTI:** Anexo interno 1111 (Línea directa del CSIRT-UNAP).
- **Botón de Reporte en Webmail:** Complemento integrado en el correo institucional para notificar mensajes sospechosos de phishing en un clic.

Sec 13.3 Clasificación de Incidentes por Tipo de Amenaza

- **Phishing Masivo o Dirigido:** Correos fraudulentos que buscan robar identidades o distribuir malware.
- **Accesos No Autorizados:** Intentos de inicio de sesión anómalos o explotación de credenciales institucionales.
- **Infecciones por Malware / Ransomware:** Ejecución de código malicioso en servidores o computadoras de oficinas.
- **Exfiltración de Información:** Fuga o extracción no autorizada de bases de datos o expedientes sensibles.
- **Pérdida o Sustracción de Equipos Físicos:** Extravío de portátiles o almacenamiento institucional con datos sensibles.

14 CAPACITACIÓN Y CONCIENTIZACIÓN

En este capítulo se establece el programa integral de concientización y formación en seguridad digital para toda la comunidad universitaria.

Sec 14.1 Campaña Permanente de Concientización

Se implementará un plan continuo de sensibilización enfocado en mitigar el factor humano como vector de ataque:

- **Ingeniería Social y Phishing:** Talleres prácticos para reconocer correos apócrifos, enlaces sospechosos y técnicas de manipulación psicológica.
- **Contraseñas Robustas y Gestión de Identidad:** Uso de contraseñas de alta entropía, adopción de gestores de contraseñas y activación obligatoria de MFA.
- **Manejo Seguro de Medios Extraíbles (USB):** Protocolos para evitar la conexión de dispositivos USB desconocidos en computadoras institucionales.
- **Navegación Segura y Protección de Datos:** Pautas para identificar certificados HTTPS válidos y evitar el ingreso de credenciales en redes Wi-Fi públicas.

Sec 14.2 Simulaciones Semestrales de Phishing Controlado

La OTI ejecutará ejercicios semestrales de simulación de phishing no destructivo hacia el personal docente y administrativo, con el objetivo de medir la susceptibilidad institucional, capacitar en tiempo real a los usuarios que caigan en el señuelo y evaluar la tasa de reporte voluntario.

Sec 14.3 Módulos de Formación Especializada para Personal Técnico

Dirigidos a los administradores de sistemas, redes y desarrolladores de software de la OTI:

- **Desarrollo Seguro de Software (OWASP Top 10):** Técnicas de codificación defensiva, sanitización de entradas, prevención de inyecciones SQL/XSS y validación de APIs REST.
- **Hardening de Infraestructura:** Configuración segura de servidores web Nginx/Apache, bastionado de sistemas operativos Linux y gestión segura de bases de datos.
- **Análisis de Logs y Cacería de Amenazas (Threat Hunting):** Uso avanzado de consolas SIEM para la identificación de anomalías y respuesta a intrusiones.

15 INDICADORES DE CUMPLIMIENTO (MÉTRICAS Y KPIS)

En este capítulo se establecen las métricas e Indicadores Clave de Desempeño (KPIs) para evaluar cuantitativamente la eficacia, madurez y avance del plan de ciberseguridad.

Sec 15.1 Cuadro de Mando de Métricas de Ciberseguridad

Los siguientes indicadores serán reportados trimestralmente al Comité de Gobierno Digital de la UNAP:

Indicador / Métrica	Fórmula de Cálculo	Meta Esperada	Frecuencia
Porcentaje de activos inventariados	$\frac{\text{Act. Catalogados}}{\text{Act. Totales}} \times 100$	$\geq 98\,\%$	Mensual
Cobertura de evaluación STRIDE	$\frac{\text{Sist. Modelados}}{\text{Sist. Críticos}} \times 100$	$100\,\%$	Semestral
Remediación de fallas críticas	Tiempo promedio de resolución de hallazgos	< 72 horas	Continuo
Cuentas con MFA activo	$\frac{\text{Cuentas con MFA}}{\text{Total Cuentas}} \times 100$	$100\,\%$	Mensual
Tasa de clics en phishing	$\frac{\text{Clics Phishing}}{\text{Total Evaluados}} \times 100$	$\leq 8\,\%$	Semestral
Tiempo medio de detección (MTTD)	Promedio de horas transcurridas desde el evento	< 2 horas	Mensual
Tiempo medio de respuesta (MTTR)	Promedio de horas para contención efectiva	< 4 horas	Mensual
Éxito en restauración de backups	$\frac{\text{Ensayos Exitosos}}{\text{Total Ensayos}} \times 100$	$100\,\%$	Semestral

ANEXOS: EVIDENCIAS Y DOCUMENTACIÓN DE SOPORTE

En esta sección se compilan las matrices técnicas, evidencias operativas y formatos de gestión que sustentan el plan de ciberseguridad.

Sec Anexo 1: Inventario de Activos (Mapeo OSINT)

Tabla consolidada de los subdominios y servidores identificados mediante fuentes abiertas (`crt.sh` y DNS):

Subdominio Identificado	Dirección IP	Registro SSL / Origen	Estado Operativo
`matricula.unap.edu.pe`	161.132.24.61	Let's Encrypt Authority	Activo (Producción)
`campus.unap.edu.pe`	161.132.24.62	Let's Encrypt Authority	Activo (Producción)
`sitrad.unap.edu.pe`	161.132.24.63	cPanel / Sectigo SSL	Activo (Administrativo)
`repositorio.unap.edu.pe`	161.132.24.64	GlobalSign Root CA	Activo (Académico)
`dev.unap.edu.pe`	161.132.24.70	Certificado autofirmado	Riesgo (Entorno Dev)
`prue1.unap.edu.pe`	161.132.24.71	Certificado expirado	Riesgo (Entorno Legado)

Sec Anexo 2: Matriz de Criticidad de Activos (Tríada CIA)

Calificación de impacto institucional basada en Confidencialidad (C), Integridad (I) y Disponibilidad (A):

Activo Tecnológico	Confidencialidad	Integridad	Disponibilidad	Nivel Consolidado
Base de Datos Central	Muy Alto	Muy Alto	Muy Alto	**Crítico**
Sistema de Matrícula	Alto	Muy Alto	Muy Alto	**Crítico**
Campus Virtual Moodle	Medio	Alto	Muy Alto	**Crítico**
Correo Institucional	Muy Alto	Alto	Alto	**Alto**
Portal Web de Facultades	Bajo	Medio	Medio	**Medio**

Sec Anexo 3: Matriz STRIDE y Evidencias Técnicas

- **Diagrama de Flujo de Datos (DFD Nivel 1):** Navegador Cliente ↔ Reverse Proxy Nginx ↔ Backend ASP.NET Core ↔ Base de Datos.

- **Captura de Cabeceras HTTP (DevTools F12):** Exposición pública de la versión del servidor web en `matricula.unap.edu.pe`:

>_ | Evidencia F12: Cabeceras HTTP en matricula.unap.edu.pe

```
HTTP/1.1 200 OK
Server: nginx/1.16.1
Date: Sat, 17 Oct 2026 15:20:00 GMT
Content-Type: text/html; charset=utf-8
Set-Cookie: .AspNetCore.Cookies=CfDJ8...; path=/; HttpOnly; SameSite=Lax
# NOTA: Ausencia de cabecera Strict-Transport-Security (HSTS desactivado)
# NOTA: La bandera 'Secure' no se encuentra forzada en todas las cookies
```

Sec Anexo 4: Matriz MITRE ATT&CK y Configuración de Reglas

Mapeo sistemático de técnicas adversarias y correspondencia con reglas de detección en el SIEM institucional Wazuh.

Sec Anexo 5: Cyber Kill Chain y Evidencias de Dominio

- **Flujograma del ataque en 7 etapas:** Reconocimiento → Armamento → Entrega → Explotación → Instalación → C2 → Objetivos.

- **Evidencia DNS de vulnerabilidad en correo institucional:**

>_ | Evidencia DNS: Registros DMARC y SPF en unap.edu.pe

```
$ host -t txt _dmarc.unap.edu.pe
Host _dmarc.unap.edu.pe not found: 3(NXDOMAIN)

$ host -t txt unap.edu.pe
unap.edu.pe descriptive text 'v=spf1 ip4:161.132.24.0/24 include:_spf.
    google.com ~all'
```

Sec Anexo 6: Matriz Zero Trust y Postura de Red

- **Negociación TLS en campus.unap.edu.pe:** Inspección de certificados que confirma ausencia de precarga HSTS.
- **Esquema de Microsegmentación:** Aislamiento de VLAN 10 (Servidores), VLAN 20 (Administración), VLAN 30 (Docencia), VLAN 40 (Alumnos) y VLAN 60 (Wi-Fi Invitados).

Sec Anexo 7: Registro de Incidentes (Boleta Formal)

Formato estandarizado para la notificación interna y reporte formal ante el CSIRT-UNAP con campos de fecha, reportante, activo afectado, criticidad y vector preliminar.

Sec Anexo 8: Cronograma Anual de Implementación

Plan de trabajo estructurado a 12 meses (Fase 1: Diagnóstico e inventario; Fase 2: Despliegue de MFA y WAF; Fase 3: Hardening y SIEM; Fase 4: Auditoría y simulaciones de phishing).

Sec Anexo 9: Cuadro de Mando de Indicadores

Matriz de seguimiento de KPIs operativos (MTTD < 2 h, MTTR < 4 h, $100\,\%$ de cuentas docentes con MFA).

Sec Anexo 10: Plan de Capacitación y Concientización

Calendario temático semestral de talleres para docentes, alumnos y módulos especializados para el equipo técnico de la OTI en OWASP Top 10.

BIBLIOGRAFÍA

Congreso de la Republica del Peru. Ley nro. 29733: Ley de proteccion de datos personales y su reglamento, 2011.

FIRST. Common vulnerability scoring system v3.1: Specification document, 2019.

Michael Howard and David LeBlanc. *Writing Secure Code*. Microsoft Press, Redmond, WA, 2nd edition, 2003.

Eric M Hutchins, Michael J Cloppert, and Rohan M Amin. Intelligence-driven computer network defense informed by analysis of adversary campaigns and intrusion kill chains. *Leading Issues in Information Warfare & Security Research*, 1(1):80–106, 2011.

ISO/IEC. Iso/iec 27001:2022 information security, cybersecurity and privacy protection — information security management systems — requirements, 2022.

Loren Kohnfelder and Praerit Garg. The threats to our products. Technical report, Microsoft Corporation, 1999. Microsoft Interface Security Report.

J. D. Meier, Alex Mackman, Michael Dunner, Srinath Vasireddy, Ray Escamilla, and Anand Murukan. Improving web application security: Threats and countermeasures. Technical report, Microsoft Corporation, 2003.

NIST. Guide for conducting risk assessments. Technical report, NIST Special Publication 800-30 Revision 1, 2012.

NIST. Framework for improving critical infrastructure cybersecurity (version 1.1). Technical report, National Institute of Standards and Technology, 2018.

OWASP Foundation. Threat modeling cheat sheet. Technical report, Open Web Application Security Project, 2020.

OWASP Foundation. Owasp top 10: 2021 - the ten most critical web application security risks. Technical report, Open Web Application Security Project, 2021.

Karen Scarfone, Murugiah Souppaya, Amanda Cody, and Angela Orebaugh. Technical guide to information security testing and assessment. Technical report, NIST Special Publication 800-115, 2008.

Adam Shostack. *Threat Modeling: Designing for Security*. John Wiley & Sons, Indianapolis, IN, 2014.

William Stallings. *Cryptography and Network Security: Principles and Practice*. Pearson, 7th edition, 2018.

The MITRE Corporation. Mitre att&ck enterprise matrix for web applications, 2023.